Ash Clements

AI Red Team · LLM and Agent Security · Offensive Security | 17 Years in Enterprise Security

Phoenix, AZ · 480-604-3412 · ash@ashclements.dev · ashclements.dev
linkedin.com/in/ash-clements-75b62b22 · github.com/BadAsh99 · Gray Swan Arena: BadAsh99

SUMMARY

Offensive security specialist with 17 years in enterprise security, now red-teaming frontier LLMs and AI agents and building the defenses. I rank #26 of 282 in Gray Swan's Breaking Ties and broke all six targets in an agentic-AI CTF, and my RAG defense AEGIS took second at the Protegrity AI Pipeline Security Hackathon. Everyone hardens the prompt. I assume the injection already won and gate what the model can touch and do, because the context window is the attack surface.

SELECTED RESULTS

- **Gray Swan Arena, Breaking Ties** (October 2026): **#26 of 282**, 21 breaks, all 5 scenarios and all 5 models, certificate GS-CO-AX9R-T1. Winner's Circle, #279 global, 40 externally judged breaks across 47 frontier models.
- **ARKX agentic-AI CTF** (October 2026): broke **6 of 6 targets** (3 Advanced, 3 Expert), a distinct Critical or High on each: expression-evaluation RCE, an unauthenticated MCP resource server past an Origin-only guard, blind OS command injection, YAML-deserialization RCE, confused-deputy privilege forgery across a multi-agent system, and a TOCTOU double-spend in a financial agent. Root cause every time: a tool trusting attacker input the agent forwarded, not the model's reasoning.
- **AEGIS**, a RAG defense built on the premise that prompt injection succeeds (PII tokenized before embed and store, scope-bound reveal, honeytoken tripwire, outbound action-gate): against a fair plaintext baseline that re-identified **100% of records** from real embeddings, AEGIS re-identified **0%** while matching the baseline retrieval utility, and a real frontier model emitted only tokens where the naive pipeline leaked PII. **Second place, 2026 Protegrity AI Pipeline Security Hackathon.**
- **Indirect Prompt Injection**, sponsored competitions: #95 of 477 (30 breaks, July 2026) and #178 of 830 (11 breaks, August 2026). Hazard Hunt (Chem/Bio/Cyber/Misc): #115 of 921, 183 breaks.
- **Method:** a 123-record attempt corpus across 47 frontier models with verbatim judge rationale; negative results logged with the same schema as breaks; every campaign ends with falsifiable rules about when a behavior class is breakable at all.

TECHNICAL SKILLS

- **AI and LLM Red Team:** indirect and direct prompt injection, jailbreaks, agentic tool-use and function-call abuse, multi-agent and RAG trust-boundary exploitation, MCP trust boundaries, confused-deputy and privilege forgery, unsafe delegation, multimodal (image) attacks, adversarial scenario design, break verification and judging criteria. OWASP LLM Top 10, Agentic Top 10 (ASI01 to ASI10), MITRE ATLAS, NIST AI RMF.
- **Offensive and AppSec:** application security (static analysis, XXE, XSS, secret detection), threat modeling, vulnerability assessment, public-exploit validation and variant analysis, incident and breach response.
- **Identity and Zero Trust:** Prisma Access, ZTNA, SWG, CASB, DLP, Cloud Identity Engine, User-ID, NGFW, PAN-OS, Panorama, Strata Cloud Manager.
- **Cloud and IaC:** AWS, Azure, GCP, Docker, Terraform, multi-cloud misconfiguration assessment, CIS Benchmarks.
- **Development and Automation:** Python, FastAPI, Flask, sentence-transformers, SSE streaming, Next.js, TypeScript.

PROFESSIONAL EXPERIENCE

Sr. Professional Services Consultant, SASE · Palo Alto Networks · Remote, Phoenix, AZ · 2021 to present

- For nine years, a standing part of my role across every customer: track public CVEs and zero-day exploits as they drop, reproduce their variants, map the real blast radius past the obvious surface, and walk the customer through impact and mitigation before it reaches their infrastructure or becomes public damage.
- On any critical CVE I run the cross-team working session end to end. On CVE-2024-4577 (the PHP-CGI argument-injection RCE), I mapped exposure beyond the PAN-OS management interface to every PHP-running server and device and drove mitigation across the customer's server, network and systems-engineering teams.

- Ran structured red-team exercises on a personal Prisma AIRS lab tenant against its detection and enforcement paths, covering prompt injection, tool-use abuse and agent behaviors.
- Review malware and threat logs and support customer breach and zero-day incident response. The report is the deliverable, and the audience is usually not the person who found the bug.
- Built SCMReady, a read-only parity checker that runs automated pre-cutover checks on Panorama to Strata Cloud Manager migrations so failures surface before cutover (evaluation stage, read only); adopted internally, presented to principal and staff engineers, and requested by a Palo Alto Networks Unit 42 engineer for a customer migration.
- Design and deploy Prisma Access and Zero Trust architectures for Fortune 500, energy and telecom customers, owning the identity and enforcement layer: Cloud Identity Engine, User-ID, DLP and identity-based policy.

Sr. Technical Support Engineer, SASE · Palo Alto Networks · Remote, Phoenix, AZ · June 2017 to 2021

- Owned the hardest Prisma Access escalations, reproduced them in the lab and handed engineering the repro; several became shipped bug fixes. Wrote the internal KBs and customer-facing troubleshooting guides. Promoted to Sr. Professional Services Consultant in 2021.

Network Security Engineer · American Express (contract via ConsultNet LLC) · 2016 to 2017

- Migrated enterprise data center firewalls from legacy Cisco ASA to Palo Alto Networks NGFW with automated rule conversion and validation. Ran the HA clusters under continuous compliance in production and non-production.

Channel Development Manager · Allied Telecom Group · 2013 to 2015

- Managed an enterprise renewal portfolio and served as senior technical escalation point for complex network-infrastructure contracts across the DMV region.

IT and Network Consultant · Independent Network Development Inc (managed service provider) · 2010 to 2013

- Delivered network and security infrastructure for enterprise clients: firewall and VPN deployment, device hardening, vulnerability assessment, and remediation. Hired and mentored engineers, including one who went on to earn CISSP and CISM and serve as an interim CISO.

PROJECTS AND TOOLING

- **badash-killchain:** a cross-application attack-chain framework over a 5-service microservice deployment where one injection crosses agent and RAG trust boundaries and reaches services the attacker never contacted. Mapped to MITRE ATLAS.
- **LLMGuardT2:** fires 35 payloads across all 10 OWASP LLM Top 10 categories at live Claude and OpenAI endpoints and scores each vulnerable, partial or resistant, using embedding similarity (all-MiniLM-L6-v2) to catch paraphrased attacks a keyword matcher misses.
- **CloudGuard:** a read-only multi-cloud misconfiguration and data-exposure scanner for AWS, Azure and GCP, mapped to CIS Benchmarks and the OWASP Cloud Top 10.
- **AISeal** (independent research project, built on personal time): detects the OWASP LLM Top 10 and the Agentic Top 10 (ASI01 to ASI10), scores overall risk, and maps each finding to a specific EU AI Act article (9 through 15).

CERTIFICATIONS

PCNSE (2024) · HTB Certified Offensive AI Expert (COAE), in progress

EDUCATION

Coursework in Information Security Technology, ECPI College of Technology, Richmond, VA · J. Sargeant Reynolds Community College, Richmond, VA